

THE DEFINITIVE REFERENCE

Hawkeye

An industry-agnostic, AI-native compliance engine for regulated supply chains.

What this document is. The single consolidated reference for Hawkeye — vision, architecture, the rigor of the regulated-supply-chain foundation, the deep pharma-domain analysis that proves it, the per-sector market and expansion strategy, the pharma plug-in in full (including the Audit Management module specification), go-to-market and commercials, the full User Requirements Specification, and a consolidated honesty register. Built from code-verified material and current industry research; intended as the durable canon a new hire, an investor, a partner, or a senior buyer can read to understand Hawkeye completely.

How this document is organized

The flow is deliberate: vision first, then architecture, then the regulated-supply-chain rigor that justifies the architecture, then the deep analysis of the first proving ground (pharma), then the strategy that follows, then what is built today, then how it's sold, then the formal requirements set, then a single page of every honesty caveat. Read it linearly to understand Hawkeye; jump to any section as a reference.

Part	Topic	Reader value
1 • Vision	What Hawkeye is at the deepest level; the thesis in one section.	Anchors everything that follows. Read this first.
2 • Architecture	The five-pillar engine, the configuration layer, pluggable AI — code-verified.	The technical foundation; how the universal engine is built.
3 • The Rigor of Regulated Supply Chain	Why we started in pharma: the architectural elements that regulated rigor forces (ALCOA+, Part 11 e-sign, immutable trails, validated AI, sovereignty, reproducibility), and why building to that bar produces an architecture every other industry can reuse.	Explains the pharma-first choice as strategic, not accidental.
4 • The Pharma & Quality-Software Domain	Vendor-neutral research survey: EQMS & supplier-audit business processes, 40-year software evolution, present failure modes, six structural white spaces.	The deep analysis of the first plug-in's domain.
5 • Market Reckoning & Per-Sector Strategy	The honest reckoning (why "horizontal platform" is a trap; why pharma EQMS head-on is the wrong game); the rings diagram; per-sector scoring; standards convergence; the supplier-audit wedge.	How the engine expands outward, sequenced and disciplined.
6 • The Pharma Plug-in	What pharma is, today, as a configuration of the universal engine: 15 modules, AI agents, BUILT/PARTIAL/THIN status. Includes the full Audit Management module specification as the worked example of one module's depth.	What is built right now, with code-level grounding.
7 • Go-to-Market & Commercials	Free-2-PoC offer, usage-based pricing, cost model summary, sales motion. Vendor-neutral.	How Hawkeye gets sold and the unit economics.
8 • User Requirements Specification	The full URS: Part A foundational requirements, Part B white-space requirements.	The formal "shall..." requirements list, traceability-ready.
9 • Honesty Register & Roadmap	Every claim flagged for verification, consolidated; partial/thin items mapped to roadmap.	The one page to read before any external commitment.

01

Vision

An industry-agnostic, AI-native compliance engine for regulated supply chains.

The thesis in one paragraph. Hawkeye is a compliance engine that does one universal thing: it collects data from across a supply chain, processes it into a common model, validates it against the standard that applies, generates the resulting compliance artifact, and seals the result as a tamper-evident, traceable, reproducible record. The pipeline is fixed; the standard, vocabulary, rules, and report templates are configuration. That separation is what makes the engine industry-agnostic. The first plug-in is pharma — not because pharma is the endgame, but because pharma's regulatory rigor is the hardest forcing function in regulated industry, and building to that bar produces an architecture every other regulated supply chain can reuse with new configuration, not new code.

Why this matters now

Three forces are converging in 2026 to make this the right moment for an industry-agnostic compliance engine:

- **Regulatory standards are themselves harmonizing.** ISO 9001 is being revised for 2026; aerospace's AS9100 is becoming IA9100 aligned to it; automotive's IATF 16949 revision (≈2027) preserves the ISO 9001 spine; defense layers in CMMC/NIST. The deliberate industry effort to "harmonize quality, risk, and cybersecurity expectations across manufacturing sectors" onto a common ISO 9001 spine with vertical clause-packs is *exactly* the engine-plus-config architecture, at the regulatory level.
- **AI has become defensible enough to enter validated environments**, but only under the right governance — grounded outputs, citations, per-call reproducibility, human-in-the-loop sign-off. The category that delivers AI *with* that governance, not without it, opens.
- **The cross-industry seams remain unowned.** Vertical incumbents are deep but specific; horizontal platforms (ServiceNow, SAP, Salesforce) are broad but lack regulated-domain credibility. The configurable engine that travels across regulated verticals with real depth has no resident incumbent.

What Hawkeye is not

- **Not a pharma EQMS.** Pharma is the first plug-in; the product is the engine, not the pack. Competing with Veeva / MasterControl head-on in pharma depth is the wrong game and not the plan.
- **Not a horizontal "compliance platform" from day one.** That positioning is a known trap — generalists lose to specialists in every vertical. Hawkeye is *sequenced verticalization*: deep in pharma first, then earned ring-by-ring outward.
- **Not an AI-wrapper.** The engine is a real data platform + rules engine + Part-11 audit substrate. AI plugs into each pillar; turn AI off and the engine remains a deterministic workflow-and-records system.

The one-line story by audience.

To a regulated buyer: "an AI-native quality & supplier-audit platform built to GxP rigor, with reproducible AI an inspector accepts."

To a partner / channel: "a configurable compliance engine you can take into any regulated supply chain you serve."

To an investor: "the industry-agnostic compliance primitive for regulated supply chains, beachhead pharma, sequenced expansion outward — riding the ISO 9001:2026 convergence."

Vision — what we are building, what we have today

What is being built (the engine)

One configurable, multi-tenant compliance engine that any regulated supply chain can run on. Its core is five sequential pillars (data collection → processing & storage → validation against a standard → compliance report/certificate → immutable record), with a configuration layer on top that injects the per-industry standard, vocabulary, rules, and templates, and a pluggable AI layer that attaches at each pillar and each module.

What is shipped (the first plug-in)

The pharma plug-in: a full EQMS module set (document control, deviation, CAPA, change, training, complaint, risk, management review) coupled to supplier-audit management, with 6 audit AI agents, per-module AI drafters, public-data fusion from FDA/EMA/WHO, and a Part-11 audit-trail substrate. Verified module count, agents, and code structure are documented in Parts 2 and 6.

The three-layer positioning

Layer	Audience	How Hawkeye is presented
Product	Buyers (Quality, Operations, IT, Procurement)	"AI-native Quality & Supplier-Audit platform for regulated manufacturers." Concrete capabilities, modules, ROI, validation posture.
Platform	Channel partners, consultants, system integrators	"A configurable compliance engine you can take into any regulated supply chain." Per-industry configuration packs, deployment options, partner economics.
Vision	Investors, strategic partners, leadership audiences	"The industry-agnostic compliance primitive for regulated supply chains, beachhead-first, ring-by-ring outward." TAM, convergence tailwind, defensibility.

One product, three faces. Same engine, same code, three audience-specific framings. The buyer audience gets the concrete product; partners get the platform; investors get the vision. Do not mix them in one conversation.

The strategy in three sentences

- Build the engine for the hardest bar (pharma GxP), so the architecture travels.** Rigor in the foundation is reuse in the future.
- Compete on the seams, not the features.** No new feature beats incumbents at their own depth; the unoccupied space is the cross-industry primitive + reproducible AI + the EQMS↔supplier-network thread + affordability.
- Sequence outward by architectural distance, never raw market size.** The nearest ring with the most engine reuse and the strongest pull is always the next move. "Industry-agnostic" is the destination earned one vertical at a time.

Hawkeye in one sentence. An industry-agnostic compliance engine — five pillars (collect, process, validate, report, seal), a configuration layer that makes it pharma today and any regulated supply chain tomorrow, and pluggable AI that an inspector can defend — beachhead-first in pharma, sequenced outward, riding the standards-convergence tailwind, competing on the seams nobody else can own.

02

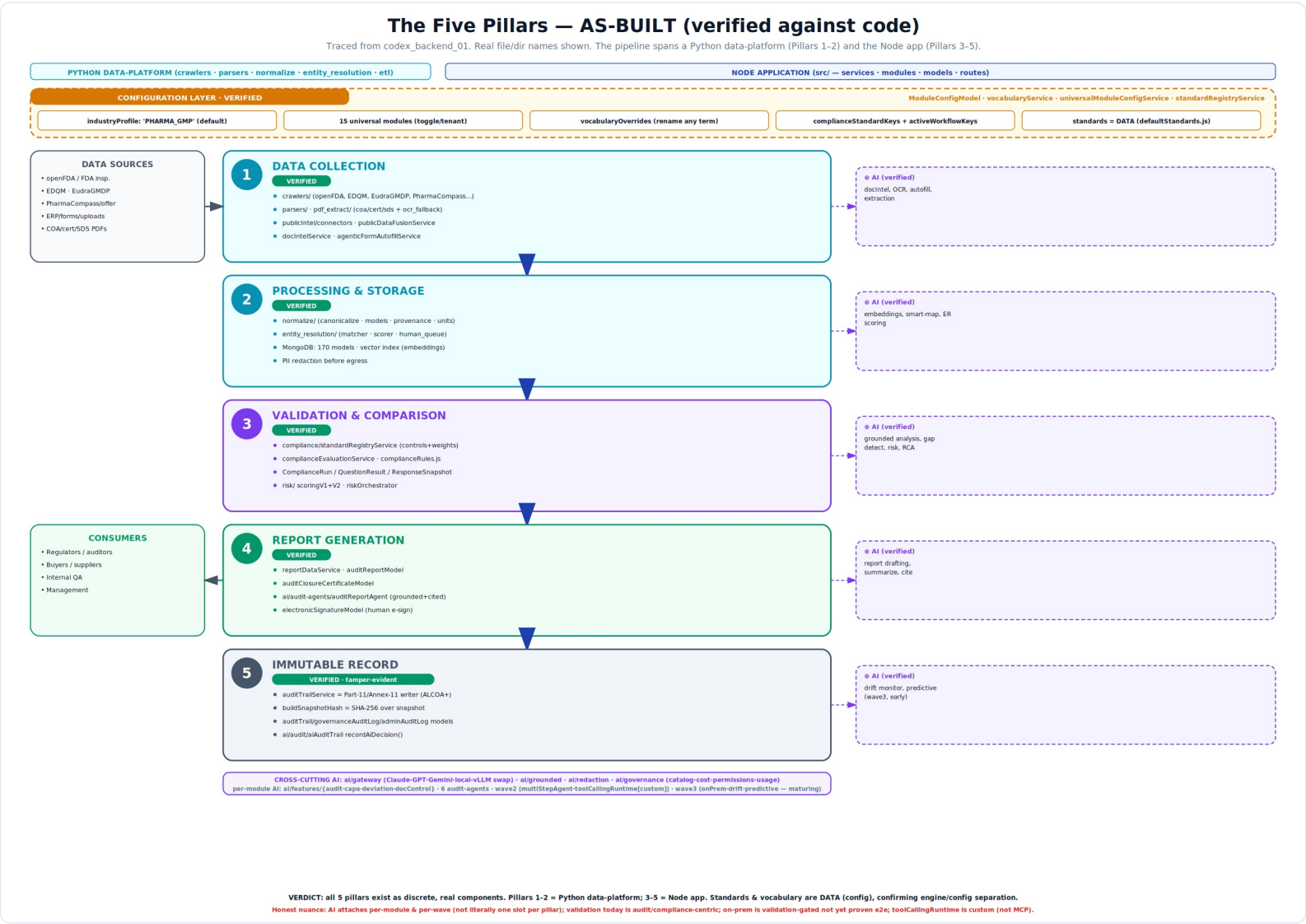
Architecture

The five-pillar engine + configuration layer + pluggable AI, verified against source.

Verification status. This section is grounded in a direct trace of the codebase (the backend repository was cloned and inspected this session). Every pillar below cites the actual files and directories that implement it. Where the as-built reality differs from the clean five-pillar picture, the difference is stated plainly. This replaces conceptual model with code-checked account.

The five-pillar pipeline

The platform does one universal thing in five sequential pillars. Strip the pharma vocabulary and the motion is identical for any standards-governed supply chain:



As-built five-pillar architecture, traced from source. Pillars 1-2 are a Python data-platform; Pillars 3-5 are the Node application. The configuration layer (top) makes the engine industry-agnostic; the AI gateway (bottom) makes the AI pluggable.

Pillar-by-pillar, with file evidence

Pillar	Status	Implementing files / directories (actual)	What it does
1 • Collection	VERIFIED	<code>crawlers/</code> (openFDA, EDQM, EudraGMDP, PharmaCompass), <code>parsers/</code> , <code>pdf_extract/</code> (COA / cert / SDS / OCR fallback), <code>publicIntel/connectors</code> , <code>docIntelService.js</code>	Structured connectors + unstructured PDF/OCR + public-data fusion + form autofill.
2 • Processing & Storage	VERIFIED	<code>normalize/</code> (canonicalize, models, provenance, units), <code>entity_resolution/</code> (matcher, scorer, human_queue), 170 Mongoose models, vector services	Canonicalize to a common model, resolve entities (with human queue), store + index.
3 • Validation	VERIFIED	<code>compliance/standardRegistryService.js</code> , <code>complianceEvaluationService.js</code> , <code>complianceRules.js</code> , <code>risk/</code> (scoringV1/V2, riskOrchestrator); models: <code>ComplianceRun</code> , <code>ComplianceQuestionResult</code> , <code>ComplianceResponseSnapshot</code>	Load configured standard's controls → compare data → verdicts + risk weighting.
4 • Report	VERIFIED	<code>reportDataService.js</code> , <code>ai/audit-agents/auditReportAgent.js</code> ; models: <code>auditReportModel</code> , <code>auditClosureCertificateModel</code> , <code>electronicSignatureModel</code>	Assemble cited report / certificate → human e-sign.
5 • Immutable Record	VERIFIED (tamper-evident)	<code>auditTrailService.js</code> (Part-11 / Annex-11 writer, ALCOA+), <code>buildSnapshotHash</code> = SHA-256; models: <code>auditTrail</code> , <code>governanceAuditLog</code> , <code>adminAuditLog</code> ; <code>ai/audit/aiAuditTrail.recordAiDecision()</code>	Hash snapshot + append-only ALCOA+ trail + AI decision record.

One precision the code forces. Pillar 5 is **tamper-evident**: per-record SHA-256 hashing plus an append-only audit trail. There is no chained ledger / blockchain in the code. "Immutable record" in the honest sense means tamper-evident + append-only. Do not call it blockchain.

Architecture — configuration & pluggable AI

The configuration layer — proof of industry-agnostic by design

The claim that one engine serves many industries rests on standards, vocabulary, and workflows being **data, not code**. The source confirms this directly:

Configuration mechanism	What it proves
<code>vocabularyService.js</code>	Per-tenant vocabulary overrides — "audit", "supplier", "buyer", "finding", "capa" etc. are all renameable per tenant with a defaults fallback.
<code>universalModuleConfigService.js</code>	An explicit <code>industryProfile</code> field (default <code>'PHARMA_GMP'</code>), 15 universal modules toggled per tenant, dependency bundles, per-tenant <code>complianceStandardKeys</code> + <code>activeWorkflowKeys</code> .
<code>modules/compliance/defaultStandards.js</code>	Standards as data — e.g. <code>ICH_Q7_CFR21</code> with controls (controlId, clauseRef, standardRefs, keywords, expectedAnswer, weight). A new standard is a new data object, not new code.
<code>standardRegistryService.js</code>	Loads, sanitizes, and versions standards into the validation engine — add/swap a standard at runtime.
<code>WorkflowDefinitionService.js</code>	Tenant-scoped, versioned workflow definitions loaded by <code>workflowKey</code> — the lifecycle is data.

The engine/configuration test passes. Adding a new industry should require a new configuration pack (vocabulary + standards + workflow + module toggles), not edits to the pipeline. The code shows exactly these as data-driven, tenant-resolved structures. **industryProfile** defaults to `PHARMA_GMP` and the shipped standards library is pharma (ICH Q7 + 21 CFR) — so the engine is industry-agnostic *by construction*, with pharma the *instantiated, proven* vertical; other industries are supported config slots awaiting their packs.

Pluggable AI — per pillar, per module, per wave

Layer	What's built (verified)
Gateway	<code>ai/gateway/</code> — Anthropic / OpenAI / Gemini providers + local-vLLM path. Swap model per capability.
Grounded generation	<code>ai/grounded/groundedGenerationService.js</code> — every claim must cite a source, or returns "insufficient evidence."
PII redaction	<code>ai/redaction/piiRedactionService.js</code> — strips identifiers before egress.
AI governance	<code>ai/governance/</code> — agentCatalog, agentCostTable, agentPermissionService, agentUsageService, roiCalculator. RBAC + cost metering + ROI.
Per-module AI	<code>ai/features/{audit,capa,deviation,docControl}/</code> — each module has its own drafter + prompt (observationDrafter, capaRcaDrafter, fiveWhyScaffolder, documentClassifier).
Audit agents	6 agents: auditAutofill, auditPrep, auditReport, supplierIntel, publicDataFusion, entityResolution.
Wave 2 / Wave 3	Wave 2: multiStepAgent, toolCallingRuntime (custom), activeLearningLoop. Wave 3: onPremLlmDeploy, driftMonitor, predictiveCapaEffectiveness, iotEquipmentFusion (maturing).

The governance guarantee, built in. No matter how the dials are set, two properties hold and cannot be configured away: every AI output is grounded-or-fallback (it never asserts what it cannot cite), and the AI never commits a record (a human always reviews and e-signs). Admin controls tune behaviour within these guarantees; they cannot remove them.

Two flags from the verification, carried forward. (1) The wave-2 `toolCallingRuntime.js` is **custom**, not MCP-compliant (no protocol/handshake in the code; the gateway's "MCP path" comment is a label, not an implementation). (2) The wave-3 `onPremLlmDeploy.js` is a real scaffold with a frozen `ONPREM_VALIDATION_REQUIREMENTS` (IQ/OQ/PQ, change control, DR, model card) — say "available, validation-gated," not "proven end-to-end."

Every module follows the same five pillars

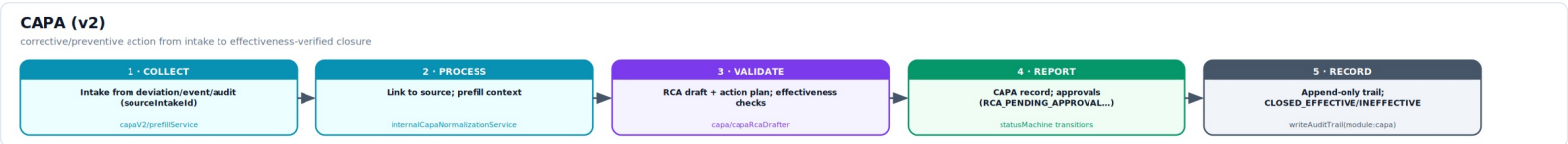
The claim that all modules share one architecture is verified: each module is the same backbone — a Model, a status/workflow machine, a service, an AI feature folder, audit-trail writes, and config resolution — differing only in domain data. The diagrams below show each module walking through the five pillars, with the actual code component (monospace) for each stage.

Deviation



An event is **collected** (intake classifier tags type/classification), **processed** (similar-event linking, normalized to the Deviation model), **validated** (5-Why scaffolder drives root cause + impact assessment), **reported** (disposition drafter writes the verdict), and **recorded** — and at close, `createCapaFromDeviation` auto-spawns a CAPA.

CAPA (v2)



A corrective action is **collected** from a deviation/event/audit, **processed** (linked + prefilled), **validated** (RCA drafter + effectiveness checks), **reported** (the CAPA record moves through approval states in `statusMachine.js`), and **recorded**.

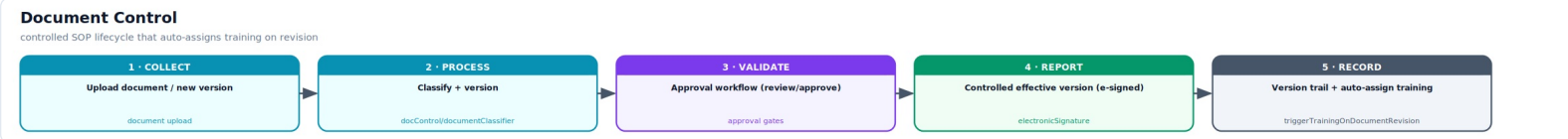
Change Control



A change is **collected**, **processed** (impact assessment, supplier/site linkage), **validated** (riskLevel + regulatoryImpact + validationRequired), **reported** (multi-step approval with signatures), and **recorded**.

Document Control, Audit, Supplier Quality

Document Control



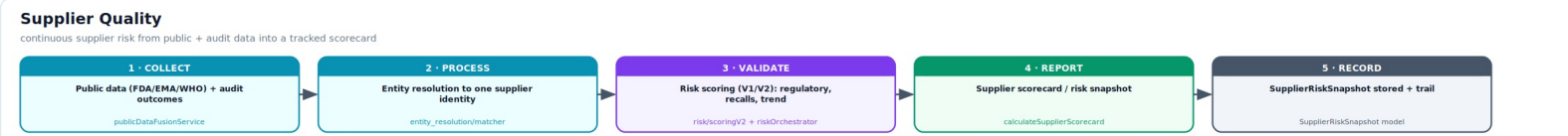
A document is **collected** (upload/new version), **processed** (classifier + versioning), **validated** (review/approve gates), **reported** (the controlled effective version, e-signed), and **recorded** (version trail) — and `triggerTrainingOnDocumentRevision` auto-assigns retraining to affected users.

Audit Management



An audit is **collected** (pre-audit questionnaire, evidence, Supplier Intel public data), **processed** (normalized to the audit master with phases/milestones), **validated** (`complianceEvaluationService` runs responses against the standard's controls + risk), **reported** (cited report + closure certificate, e-signed), and **recorded** (`buildSnapshotHash` SHA-256 + Part-11 trail). The flagship instantiation of all five pillars.

Supplier Quality



Supplier risk is **collected** (public FDA/EMA/WHO data + audit outcomes), **processed** (entity resolution to one supplier identity), **validated** (risk scoring V1/V2 across regulatory/recalls/trend), **reported** (`calculateSupplierScorecard`), and **recorded** (`SupplierRiskSnapshot` stored + trail).

The cross-module fabric. `crossModuleService.js` wires the modules together so the pillars chain across modules, not just within one: Deviation→CAPA (`createCapaFromDeviation`), Document→Training (`triggerTrainingOnDocumentRevision`), CAPA-failure/Risk→for-cause Audit (`triggerForCauseAudit`), Audit/events→Supplier scorecard (`calculateSupplierScorecard`), KPI roll-up to Management Review (`aggregateQualityKPIs`). The whole platform is one large five-pillar engine whose modules feed each other's pillar-1 intake.

The honest refinements

- **Two runtimes, not one.** Pillars 1–2 are a Python data-platform; Pillars 3–5 are the Node app. The "one pipeline" spans both.
- **AI attaches per-module and per-wave**, not literally one slot per pillar — the slot metaphor is a clean abstraction over a richer reality.
- **Validation today is audit/compliance-centric** — a genuine rules engine, instantiated for the audit-questionnaire-vs-standard flow; "validate any supply-chain data" is the generalization the engine supports but is not all-deployed today.
- "Immutable" = **tamper-evident, not blockchain**.
- **On-prem LLM = validation-gated; tool runtime = custom, not MCP.**

The Rigor of Regulated Supply Chain

Why we started in pharma: the architectural elements that GxP rigor forces — and why building to that bar produces an architecture every other industry can reuse.

The central argument. A horizontal compliance engine could in principle be built for any industry. The question is which industry's bar to build it to. The answer is: the hardest — because rigor in the foundation becomes reuse in the future. A platform built for pharmaceutical GxP must satisfy the strictest forms of every architectural property an industry-agnostic compliance engine could ever need: data integrity, electronic-signature non-repudiation, immutable trails, validated AI, model sovereignty, per-decision reproducibility. Build to that bar and every less-regulated industry inherits a system that already does more than it asks. Build to a softer bar and adding pharma later means rebuilding the foundation. The strategic logic of "start regulated" is: **do the hard architecture once.**

The seven elements that regulated rigor forces — and what each produces

Element	What GxP demands	What it produces in the engine (and where it travels)
1. ALCOA+ data integrity	Every record Attributable, Legible, Contemporaneous, Original, Accurate, Complete, Consistent, Enduring, Available — the inspector's lens on the whole system.	A common-model layer (Pillar 2) with provenance tagging on every field. Travels: every standards-driven industry (auto, aero, food, chemicals) needs the same record properties for its own audit; ALCOA+ is just the strictest formulation.
2. 21 CFR Part 11 / Annex 11 e-signature	Each signature binds signer identity + meaning + timestamp + record version; re-authentication at signing; locked records.	A signature service (Pillar 4) generalized as "any controlled record needs an e-signature." Travels: aerospace (AS9100), automotive (PPAP sign-off), defense (CMMC), food (HACCP plan approvals) — all need it.
3. Append-only audit trail	Every action attributable, time-stamped, before/after captured, prohibited from edit by any user — readable, exportable, retained.	The <code>auditTrailService</code> (Pillar 5) as a cross-module Part-11 writer. Travels: same need in every regulated industry — the audit trail is the universal compliance substrate, even where the regulation isn't pharma-named.
4. Tamper-evident record integrity	Inspector must be able to prove the record was not altered after signing.	Per-record cryptographic hashing (<code>buildSnapshotHash</code> , SHA-256). Travels: cross-party trust contexts (shared audit reports, supplier scorecards, chain-of-custody) need exactly this even more than internal pharma.
5. Validated AI & defensible reproducibility	For any AI output in a GxP-impacting step: per-call record of inputs, prompt, model, sources, confidence, signer — reproducible to an inspector.	The <code>aiAuditTrail.recordAiDecision()</code> mechanism + grounded-or-fallback discipline. Travels: every industry that admits AI into a regulated decision (which is becoming all of them) needs this; ISO 42001 makes it explicit.
6. Model sovereignty / on-prem option	Some pharma buyers cannot let proprietary process data leave their boundary, even with redaction.	The multi-LLM gateway + on-prem deployment scaffold with frozen validation requirements. Travels: aerospace/defense (ITAR, CMMC), banking, government — all have the same sovereignty requirement, often stricter.
7. Separation of duties, RBAC, validation posture	Configurer ≠ approver, deep RBAC with scope, full IQ/OQ/PQ validation lifecycle, change control on the system itself.	Configurable RBAC + role-scope, validation documentation, change-controlled configuration. Travels: every regulated industry uses the same separation-of-duties principle and accepts the same IQ/OQ/PQ validation evidence.

Rigor — why this beats the alternative

The counterfactual — what happens if you start softer

Imagine the same engine built for, say, ISO 9001 manufacturing as the beachhead instead of pharma GxP. The pipeline would look similar; the standards library would be shorter; the AI features would be the same. But the seven elements above would be present only in their lighter forms — a less strict audit trail, a non-Part-11 signature service, lighter validation posture, lighter sovereignty support. Now to enter pharma later, every one of those elements must be ratcheted up *after* production deployment: a new signature service, a new audit-trail substrate, a new validation framework, a new AI governance model. That is a foundation rebuild, not a feature addition. Conversely, building to pharma's bar first means entering ISO 9001 manufacturing later requires only removing strictness, never adding it. **Rigor is irreversible the wrong way.**

The investment thesis embedded in this choice. Pharma is not the largest market in absolute terms (discrete manufacturing is bigger by US QMS spend). Pharma is the *architectural ceiling*. By choosing it as the beachhead, the platform inherits — as a side effect of doing pharma well — every property required for every other regulated supply chain, with the only remaining work being configuration: the standard's controls, the vocabulary, the rules, the report template. The seven elements above are **infrastructure**; the per-industry pack is **configuration**. Doing the infrastructure once, to the highest bar, is the strategic move.

What this means concretely for non-pharma plug-ins

Industry	What is inherited "for free" from pharma rigor	What still must be configured
Food & Beverage (HACCP)	Audit trail, e-sign, common model, supplier risk, OCR/document intel, AI governance, validation posture.	HACCP critical-control-point definitions, recall workflows, FSMA-specific report templates.
Cosmetics (ISO 22716)	Same as above, plus the GMP-lite batch motion is near-identical.	Claim-substantiation workflow, EU 1223/2009 templates.
Cell & Gene / Blood / Tissue	Custody, hashing, signature, validation, traceability — all native strengths.	Donor consent workflow, 21 CFR 1271 controls.
Automotive (IATF 16949)	Audit trail, RBAC, supplier risk, document intel, AI governance.	PPAP/APQP packets, FMEA workflow, customer-specific requirements.
Aerospace (AS9100/IA9100)	All of the above + sovereignty/on-prem inherited from pharma's strictest tier.	FAI packets, NADCAP nuances, ITAR controls.

One precise way to say it

"We chose pharma because pharma is the only industry whose foundational architectural requirements — ALCOA+, Part 11 signatures, immutable trails, validated AI, model sovereignty, per-decision reproducibility — are *stricter than* every other regulated supply chain's. Build the engine to satisfy a pharma inspector, and you've built it for an aerospace auditor, a food safety inspector, an automotive supplier-quality engineer, and a chemicals safety officer at the same time. The pharma plug-in proves the rigor; the engine is what makes the rigor reusable. Pharma is the forcing function, not the destination."

The pivot in the rest of the document. Parts 4-5 take this rigor as established and ask: given the engine, where does the deep analysis of the pharma domain show the unsolved problems are, and which other regulated supply chains are nearest and best fit for the engine to expand into? Part 6 then shows the pharma plug-in itself — the proof that the rigor is real and instantiated.

04

The Pharma & Quality-Software Domain

The vendor-neutral picture of the world the pharma plug-in operates in: business processes, software evolution, present failure modes, and the six structural white spaces.

What this part is. A condensed research survey of the EQMS and supplier-audit category — its standard business processes, its forty-year software-evolution arc, the failure modes the literature consistently names, and the six structural problem spaces no generation of software has fully resolved. Hawkeye is intentionally absent from this part. The point is to understand the domain as the domain understands itself — which is the basis for the strategy and white-space play in Part 5.

The EQMS business process

Regulated manufacturing rests on a documented promise: that products are made under control, and that the manufacturer can prove it. Modern quality management operationalises that promise as a set of interlocking, closed-loop processes sharing one documented, signed, and audit-trailed substrate. The standard module set is strikingly consistent across vendors and industries because it is shaped less by software design than by regulation — chiefly the U.S. FDA's 21 CFR Parts 210/211 and 820, the EU's EudraLex Volume 4 (GMP) and Annex 11, ISO 9001 and ISO 13485, and ICH Q9 (quality risk management) and Q10 (pharmaceutical quality system).

Process / module	The business process	Regulatory anchor
Document control	Author → review → approve → effective → periodic review → retire, with enforced version control. Foundation; first artefact an inspector opens.	21 CFR 211.100/180; Annex 11
Deviation / NC	Detect → record → classify by risk → investigate (root cause) → disposition → link to CAPA.	21 CFR 211.192; ICH Q10
CAPA	Initiate → investigate root cause → action plan → implement → verify effectiveness → close. The closed loop at the heart of continuous improvement.	21 CFR 820.100; ICH Q10
Change control	Request → impact/risk assessment → approval (often multi-step) → implement → close.	ICH Q10; Annex 15
Training	Assign on role/SOP change → complete → assess competency → record. Auto-triggered by document revision.	21 CFR 211.25
Complaint / OOS-OOT	Intake → triage → investigate → regulatory-reporting assessment → CAPA.	21 CFR 211.198
Risk management	Identify → assess → control → review; threaded through every other process.	ICH Q9; ISO 14971
Management review	Aggregate quality KPIs → review → decide → act.	ICH Q10

Two properties make these processes a **system** rather than a collection of tools. First, **data integrity**, codified in the ALCOA+ principle. Second, **interconnection** — a deviation spawns a CAPA, a change triggers retraining, a complaint may trigger a regulatory report, a supplier problem triggers a for-cause audit. The industry term that has emerged is the **"digital thread"** — end-to-end traceability across modules.

Domain — supplier-audit process & software evolution

The supplier / vendor-audit business process

Supplier-audit management is frequently treated as a sub-module of EQMS, but its business process is materially different. Where internal quality answers "is my operation in control?", supplier audit answers "are the parties I depend on in control, and can I prove I verified them?" It is an ongoing qualification-and-monitoring relationship structured in four stages:

1. **Initial evaluation and risk classification** — questionnaire, document review, certifications, prior performance; risk-classified to set audit depth.
2. **Qualification audit** in three sub-stages: *pre-audit prep* (scope, auditor qualification, agenda, pre-questionnaire, pre-reads, risk review); *on-site or remote verification* (opening meeting, facility inspection, documentation review, evidence capture); *post-audit follow-up* (findings classified, audit report, CAPA requested, CAPA evaluation, approval decision).
3. **Quality agreement & approval** — formal agreement on roles, specs, acceptance criteria; approved-supplier-list entry.
4. **Ongoing monitoring & periodic re-evaluation** — performance tracking, periodic re-audit, *for-cause* audits triggered by events.

The structural redundancy problem. Every buyer audits the same suppliers independently, and every supplier hosts substantially the same audit repeatedly. A contract manufacturer serving 50 clients may host dozens of near-identical GMP audits per year; each client separately commissions, schedules, travels to, and documents that audit. The aggregate waste is enormous and intrinsic to the process. The principal innovations in supplier-audit software over the last fifteen years have been attempts to attack precisely this redundancy.

The evolution of the software — five generations

Generation / era	What it added
Pre-history (to 1980s)	Conceptual foundations: Taylor (1911), Shewhart's SPC (1924), Deming. 1970s GMP-into-law (regulations move from suggestion to legal requirement). Fixed the <i>processes</i> all later software would digitise.
Gen 1 — 1980s	Data automation. SPC and inspection-data tools on the factory floor — point tools, not management systems. Digitised measurement, not the quality process.
Gen 2 — 1990s/2000s	The standards-driven and homegrown era. ISO 9000/9001 + desktop databases (Access, SQL) produced widespread homegrown systems — brittle, person-dependent, hard to validate.
Gen 3 — 2000s/2010s	The enterprise eQMS. Commercial, validated systems with 21 CFR Part 11 / Annex 11 e-signature and audit trail. Heavy, on-premise or single-tenant, validation-heavy.
Gen 4 — 2010s/early 2020s	Cloud / SaaS. Same eQMS in multi-tenant cloud; COVID-19 accelerated remote access. The conceptual shift: from "document-centric compliance" to "evidence-centric execution."
Gen 5 — 2020s-now	The intelligence era. AI/ML for CAPA drafting, document classification, supplier risk, predictive quality. Regulatory shifts: FDA QMSR (2026) aligning 21 CFR 820 to ISO 13485; ISO 42001 for AI governance.

The supplier-audit software evolved on a separate, more compressed trajectory: from module-within-EQMS, to the Rx-360 consortium's shared-audit programs (founded 2009), to commercial audit-network platforms (Qualifyze founded 2019, growing into the world's largest pharmaceutical audit database with AI risk insights and ~\$54M raised by 2025). The deep observation: **EQMS evolved vertically (single-company); supplier-audit evolved horizontally (the network). The two have not converged.**

Domain — present state & the six white spaces

The present state and its recurring failure modes

By 2026 the category has matured to broad feature parity at each tier. The standard module set, Part 11 / Annex 11 e-sign + audit trails, ALCOA+, cloud delivery, configurable workflows, and some form of AI are now **table stakes**, not differentiators. The literature and practitioner commentary are remarkably consistent about what still fails — and the failures are not missing features.

- **Integration / interoperability — the dominant failure mode.** "Implementation failures stem from poor adoption or weak integration rather than missing features." An eQMS that cannot connect to ERP/LIMS/MES/PLM forces manual export and duplicate data entry; the digital thread breaks at every system boundary.
- **Adoption / usability.** Premium systems criticized for lengthy implementations and complex interfaces — "even the most compliant system fails if workflows are cumbersome." Validation makes systems trustworthy *and* rigid.
- **Unstructured-data overload.** A growing fraction of quality-relevant information — scanned audit reports, certificates, emails, spreadsheets — is unstructured; traditional QMS handle it poorly.
- **Validation transparency of AI.** As AI enters validated environments, the boundary between what is vendor-validated and what is customer responsibility is frequently unclear. ISO 42001 is a partial response; the underlying difficulty — proving per-decision reproducibility — remains substantially open.

The six structural white spaces

Synthesizing the processes, the evolution, and the failure modes, six structural problem spaces emerge — persistent, recognized problems that no generation of the software has fully resolved.

White space	The unmet need
WS1 — EQMS ↔ supplier-audit-network coupling	Internal-quality software and supplier-audit networks evolved separately and have not converged. The digital thread breaks at the company boundary — precisely where supply-chain risk concentrates. No category owns the coupling.
WS2 — Reproducible, defensible AI in validated environments	The field lacks a widely accepted means of demonstrating, per decision, exactly how an AI output was produced — data, model, sources, reasoning — in a form an inspector accepts and can reproduce.
WS3 — Live external/public-data fusion into quality decisions	Supplier risk and quality decisions are still largely driven by self-reported information and periodic audit cadence. The large body of real-time public regulatory signal exists but is not systematically fused into quality.
WS4 — True interoperability & cross-system digital thread	The industry has integrated <i>within</i> vendors and failed to integrate <i>across</i> them; an open, reliable digital thread across the enterprise stack remains an unmet need.
WS5 — Affordable, validated, intelligent quality for SMBs & emerging markets	The capability frontier (deep, AI-enabled, integrated systems) and the affordability frontier (deployable by a small or emerging-market manufacturer) do not coincide. A large underserved population is caught between.
WS6 — Genuinely industry-agnostic compliance engine	The canonical processes are abstractly the same across regulated industries, yet software is usually built for one regime. A configurable engine instantiable per industry is frequently theorised, rarely delivered.

The common thread. None of the six is a missing *feature* — the category is feature-rich and converging. Each is a missing *connection*: between internal and external quality (1), between automation and trust (2), between public reality and private records (3), between systems (4), between capability and affordability (5), and between one industry's solution and another's (6). The field's forty-year evolution has been overwhelmingly **vertical** — deeper functionality within silos — and its unsolved problems are overwhelmingly **horizontal**. The next meaningful generation of this software will be defined less by what new functions it adds than by which of these seams it closes.

05

Market Reckoning & Per-Sector Strategy

The hard reckoning first; then the rings, per-sector scoring, the standards-convergence tailwind, and the sequenced expansion path.

The hard questions answered straight, before any market map.

"Aren't the white spaces already being addressed by incumbents?" Partly true. Inside pharma, incumbents *are* closing the in-vertical gaps — ComplianceQuest ships grounded, cited AI; Qualifyze has a live supplier-audit network with AI risk insights; MasterControl is certified to ISO 42001. If the bet were "out-feature Veeva in pharma," it would be a losing bet. **But** the six white spaces share a trait: they are *horizontal seams*, and the deepest of them (a configurable industry-agnostic engine, the cross-industry primitive) is the one thing no vertical incumbent will ever build, because their moat *is* vertical depth. Veeva becoming industry-agnostic would destroy what makes Veeva valuable. The unoccupied space is real — but it is not "a better pharma EQMS." It is the cross-industry compliance primitive.

"Horizontal platform" is a known trap — name it. The graveyard is full of horizontal compliance platforms that lost to a focused vertical specialist in every single vertical, because regulated buyers want depth, references, and validation specific to their industry. "We do everything" reads as "best at nothing." The only horizontal strategy that works is **sequenced verticalization**: win one vertical deeply enough to earn references and a validated core, then expand to the *adjacent* vertical that reuses the most architecture — never "horizontal from day one." This is exactly the strategy: start regulated, get to agnostic, by sequence, not ambition.

Market sizing — where the spend concentrates

~\$12.5B Quality Mgmt Software (2025) → ~\$20-31B by 2030-34
~10-11% QMS market CAGR
~\$15.5B Supplier Quality Mgmt apps (2026) → ~\$42B by 2036
~13.8% Life-sciences QMS CAGR (fastest vertical)

Vertical	Share / growth signal	What it means for entry
Discrete manufacturing (auto, aero, industrial)	Largest single block — ~32% of US QMS spend	Biggest pool, but defended by IATF/AS9100 specialists; enter via supplier-audit angle.
Healthcare / life sciences	Fastest-growing — ~13.8% CAGR	The beachhead; highest regulatory pull, highest willingness to pay.
Chemicals + Food & Beverage	83% expect bigger quality budgets (Verdantix 2025)	Strongest demand momentum; near-adjacent to the core.
Automotive (IATF 16949)	Compliance "nearly mandatory" for suppliers	Huge captive supplier base; audit redundancy is acute.

The honest read on TAM. The headline numbers (\$12.5B QMS, \$15.5B SQM) are *total* markets — the addressable slice for a new entrant is far smaller and concentrated in the under-served edges: SMBs and emerging markets the incumbents price out, and the cross-vertical buyers no single specialist serves. Do not pitch the \$40B; pitch the specific, winnable wedge in each ring. TAM justifies the ambition; SAM/SOM justify the plan.

Master Reference v1.0 · Part 5 · Market · page 14

Sectors by architectural distance from the core

Sequence expansion by how much the engine can *reuse*, not by raw market size. The nearest ring that can be won with the least new configuration is the next move — never the biggest TAM.

Industry Expansion Map — by architectural distance from the regulated core

The same five-pillar engine (collect → validate vs standard → report → immutable record) applies outward in rings. Distance = how much new configuration + data each ring needs.

READING THE RINGS

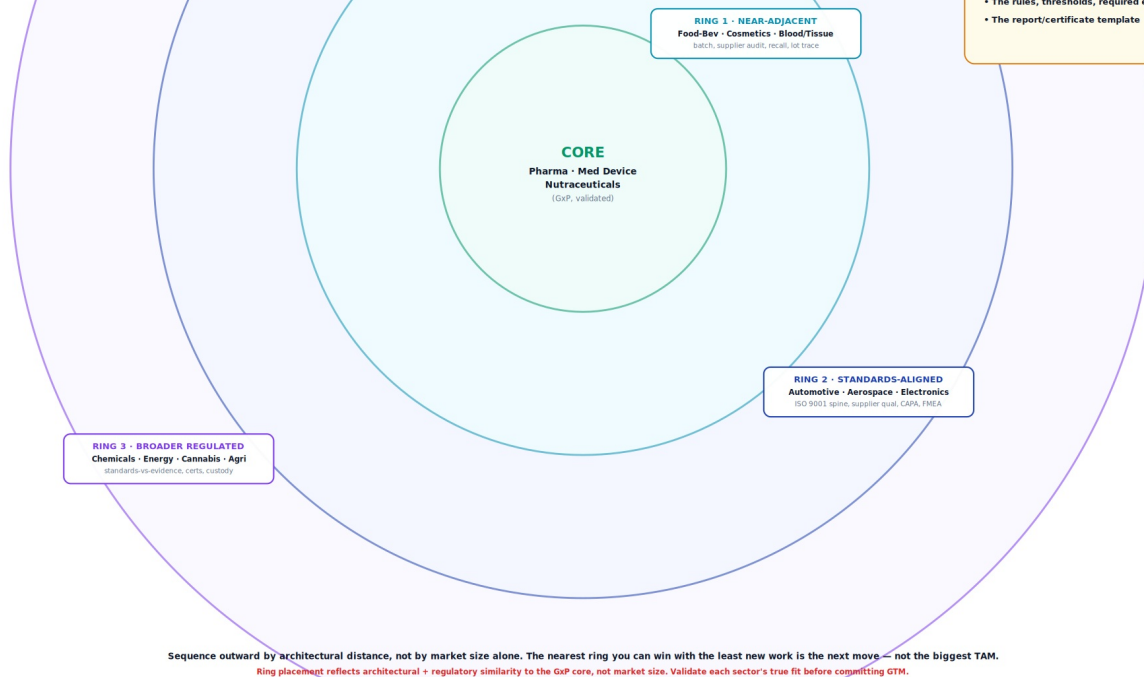
Distance from core = how much NEW work to enter: new standard pack, new data sources, new references, new validation. Nearer rings reuse more of the pharma beachhead; outer rings need more new configuration and go-to-market.

WHAT STAYS CONSTANT (the engine)

- Collect structured + unstructured data
- Validate against a standard's controls
- Generate the compliance/cert artifact
- Seal as tamper-evident immutable record
- AI assists each step, human signs

WHAT CHANGES PER INDUSTRY (config)

- The standard (GMP / HACCP / IATF / AS9100)
- The vocabulary (batch / lot / part / sample)
- The rules, thresholds, required evidence
- The report/certificate template



The constant engine at the centre; concentric rings of industries by architectural + regulatory similarity. Inner rings reuse the most of the GxP beachhead.

The macro tailwind — the standards are converging. ISO 9001 is being revised for 2026; aerospace's AS9100 is becoming IA9100 aligned to it; automotive's IATF 16949 revision (~2027) preserves the ISO 9001 spine; defense layers in CMMC/NIST. Industry bodies are deliberately harmonizing quality, risk, and cybersecurity expectations across manufacturing sectors onto a common ISO 9001 spine with vertical clause-packs on top. That is *exactly* the engine-plus-config architecture. The regulatory world is moving toward the shape the platform already has.

Sector deep-dive — core & near-adjacent rings

Fit = architectural reuse of the engine. Pull = regulatory / buyer pressure to adopt.

Sector	Standard(s)	Core use case for the engine	Fit	Pull	Incumbents / whitespace
Pharma / Biotech (CORE)	GMP, 21 CFR 210/211, ICH Q7-Q10	EQMS + supplier audit; batch release; deviation→CAPA; public-data risk	Very high	Very high	Veeva, MasterControl, ComplianceQuest, Qualifyze. White: SMB/emerging-market + reproducible AI + EQMS↔network coupling.
Medical Devices (CORE)	ISO 13485, FDA QMSR (2026), MDR	Design-history + CAPA + complaint + supplier qual; QMSR harmonization	Very high	Very high	Greenlight Guru, MasterControl. White: QMSR-transition + AI + affordability.
Nutraceuticals / Supplements (CORE)	21 CFR 111 cGMP	Same GxP motion lighter; supplier & ingredient qualification	Very high	Med	Underserved by premium tools; price-sensitive. White: affordable GxP-grade.
Food & Beverage (RING 1)	HACCP, FDA FSMA, FSSC 22000, BRCGS	Critical-control-point monitoring, supplier audit, recall, lot traceability	High	High	SafeFood/TraceGains/SafetyChain. White: AI + supplier-network + cross-site. Strong budget momentum.
Cosmetics / Personal Care (RING 1)	ISO 22716 GMP, EU 1223/2009	GMP-lite batch + supplier + claim substantiation	High	Med	Few dedicated players; often on generic QMS. White: purpose-built + affordable.
Blood / Tissue / Cell & Gene (RING 1)	21 CFR 1271, GTP, chain-of-custody	Chain-of-custody + donor/lot traceability + release	High	High	Niche, under-digitized. White: custody + immutable record is a native strength.

Pattern in the core + Ring 1. All share the GxP "batch/lot, supplier audit, recall, validated record" shape — so the engine reuses 70-90% of its pharma configuration. These are the cheapest, fastest expansions. **Food & Beverage is the standout first hop:** high pull, strong budget growth, acute supplier-audit redundancy, and architecturally near-identical to pharma supplier audit.

Sector deep-dive — standards-aligned & broader

Sector	Standard(s)	Core use case	Fit	Pull	Incumbents / whitespace
Automotive (RING 2)	IATF 16949, APQP, PPAP, FMEA	Supplier quality + PPAP/APQP evidence + audit + nonconformance	High*	Very high	Big specialists (Plex, etc.). White: AI + supplier-audit-network across the captive tier-N base.
Aerospace & Defense (RING 2)	AS9100→IA9100, NADCAP, ITAR, CMMC	Supplier qual + FAI + traceability + cyber/export controls	High*	Very high	Net-Inspect, etc. White: AS9100→ISO9001:2026→CMMC convergence + on-prem/sovereignty.
Electronics / Semiconductors (RING 2)	IPC, RoHS, REACH, conflict minerals	Supplier + substance compliance + traceability	Med-high	Med-high	Assent/iPoint (substance). White: unify quality + substance + supplier audit.
Chemicals (RING 3)	REACH, GHS, ISO 9001, Responsible Care	SDS management + supplier + substance validation + record	Med	High	Specialist EHS/SDS tools. White: quality + SDS + audit in one. 83% expect budget growth.
Energy / Oil & Gas (RING 3)	API specs, ISO 14001/45001	Asset integrity + supplier + inspection records + audit	Med-low	Med	Heavy EAM/APM incumbents. White: thinner; more new config needed.
Cannabis (RING 3)	State seed-to-sale, GACP, GPP	Seed-to-sale custody + testing + compliance record	Med	High (where legal)	Metrc/seed-to-sale niche. White: GxP-grade quality + custody.
Agriculture / Agri-food (RING 3)	GACP, GlobalG.A.P., organic	Farm-to-processor certification + supplier + custody	Med	Med	Fragmented. White: certification + traceability engine.

* Auto/aero "High*": engine maps well, but carries industry-specific evidence artifacts (PPAP, FAI, NADCAP) needing real configuration — more work than Ring 1.

The expansion sequence — earned, not declared

Phase	Target	Why now / what it proves	Reuse vs new
Now	Pharma + adjacent GxP — SMB / emerging-market wedge	Highest pull; the wedge incumbents ignore; proves engine + reproducible AI + affordability	Baseline
Next	Food & Beverage (Ring 1)	Near-identical supplier-audit + recall + lot-trace; strong budget growth; first "agnostic" proof	~75% reuse / new HACCP pack
Then	Cosmetics, Blood/Tissue, Cell & Gene	Same GxP-lite + custody motion; custody is native	~70% reuse
Later	Auto / Aero supplier-audit angle	Enter via supplier-audit-network wedge; ride ISO 9001:2026 convergence	~50% reuse / PPAP, FAI packs
Horizon	Chemicals, Cannabis, Agri, Energy	Larger config lift; pursue where a buyer/partner pulls	~40% reuse

The cross-ring wedge — supplier audit. Supplier qualification + audit is the one use case present in every sector and the one with the worst incumbent coverage (audit-network players are pharma-only; EQMS players don't run networks). Leading each new vertical with the supplier-audit wedge — rather than the full EQMS — is the lowest-config, highest-pain way to enter; expand into internal quality once inside.

06

The Pharma Plug-in

What pharma is, today, as a configuration of the universal engine: 15 modules, AI agents, standards library, status — with the full Audit Management module specification as the worked example.

What this part is. Pharma framed not as "what Hawkeye is" but as **the first plug-in pack** instantiating the universal engine described in Part 2. The 15 modules below are the **DEFAULT_MODULES** set with `industryProfile = 'PHARMA_GMP'`; the standards library is ICH Q7 + 21 CFR 21; the workflows are pharma-tuned. The same engine, the same code, the same architecture — with a pharma configuration on top. Every status flag (BUILT/PARTIAL/THIN) below is traced to the source repository this session.

The 15 universal modules (pharma pack)

Module (config key)	Status	Evidence in code
AUDIT_MANAGEMENT	BUILT	auditEngine modulePacks (phases/milestones), auditRequestsMasterModel, workflow transitions, auditReportAgent
DOCUMENT_CONTROL	BUILT	docControl classifier + versioning; auto-training trigger via crossModuleService
CAPA_MANAGEMENT	BUILT	capaV2 statusMachine (full transition map), prefillService, RCA drafter
CHANGE_CONTROL	BUILT	ChangeControlModel; multi-step approval; triggersRequalification field
EVENT_MANAGEMENT	PARTIAL	EVENT_MANAGEMENT module config; complaintTriageService (wave3); regulatory-reporting assessment
TRAINING_MANAGEMENT	PARTIAL	auto-assign on doc revision; wave2 training subdir
RISK_MANAGEMENT	BUILT	risk/ (scoringV1+V2, orchestrator, trend, network exposure)
SUPPLIER_QUALITY	BUILT	SupplierRiskSnapshot (12 dimensions: regulatory, recalls, responsiveness, CAPA, transparency, evidenceTrust, networkExposure, trend, volatility, earlyWarnings, auditorBiasFactor)
MANAGEMENT_REVIEW	PARTIAL	aggregateQualityKPIs (crossModuleService); wave2 mrm dir
ASSET_MANAGEMENT	PARTIAL	module config slot; depth varies
CHAIN_OF_CUSTODY	PARTIAL	Strong fit; native hashing + trail substrate; module-level UI varies
TRANSACTION_REVIEW	PARTIAL	module config slot
REGULATORY_INTEL	BUILT	publicDataFusionService; crawlers (openFDA, EDQM, EudraGMDP); publicIntel connectors
AI_ASSISTANT	BUILT	multi-LLM gateway, grounded, redaction, governance
RFQ_PROCUREMENT	THIN	module config slot; light implementation

The AI surface

Layer	What is shipped
Cross-cutting	Gateway (Anthropic/OpenAI/Gemini/local-vLLM), grounded generation, PII redaction, governance (catalog/cost/permissions/usage)
Per-module drafters	audit: observationDrafter; capa: capaRcaDrafter; deviation: fiveWhyScaffolder + intakeClassifier + similarFinder + dispositionDrafter + capaRecommender + trendAlerter; docControl: documentClassifier
6 audit agents	auditAutofill, auditPrep, auditReport, supplierIntel, publicDataFusion, entityResolution
Wave 2 (next-gen)	multiStepAgent, toolCallingRuntime (custom), activeLearningLoop, crossCompanyAudit (observationDrafter, supplierRiskDossier, realTimeFollowupSuggester)
Wave 3 (maturing)	onPremLlmDeploy (validation-gated), driftMonitor, predictiveCapaEffectiveness, iotEquipmentFusion, auditorCoach

Audit Management Module — full specification

The flagship module of the pharma plug-in, in depth: data model, lifecycle, end-user surface, roles & permissions, admin configuration, AI governance, e-signature & compliance, integrations, and audit trail.

Why Audit Management as the worked example. Audit Management is the most differentiated module in the pharma plug-in — it is the one that runs all five pillars at full depth and is the locus of the EQMS↔supplier-audit-network seam (white-space WS1). It is the best single instance to show how one module of the universal engine is configured for a specific domain at full detail. The same depth applies (by the architecture, by the cross-module substrate) to the other built modules; this is the worked exemplar.

Scope of the embedded specification

\$	Topic	What it covers
6.1	Module overview	Purpose, capabilities, where it sits in the platform
6.2	Data model	Entities & relationships (diagram)
6.3	Lifecycle	The audit state machine (diagram)
6.4	End-user screens	Operational flow (summary)
6.5	Roles & permissions	The RBAC matrix
6.6	Admin configuration	The full admin surface (diagram)
6.7	AI governance	Controlling the agents, models, grounding, redaction
6.8	E-signature & compliance	21 CFR Part 11, retention, locking
6.9	Integrations & data	ERP/supplier sync, public data, export/API
6.10	Audit trail & reproducibility	The inspection-readiness layer

6.1 — Module overview

Audit Management runs the full lifecycle of supplier, internal, and for-cause audits — from planning through conducting, findings, reporting, sign-off, and reuse. It is distinguished from a conventional audit tool by three things: AI agents that draft the slow work (supplier risk dossiers, risk-weighted questionnaires, findings reports), public-data fusion that pulls live FDA/EMA/WHO signals into risk assessment, and a per-call AI audit trail that makes every AI output reproducible and defensible.

Core capabilities

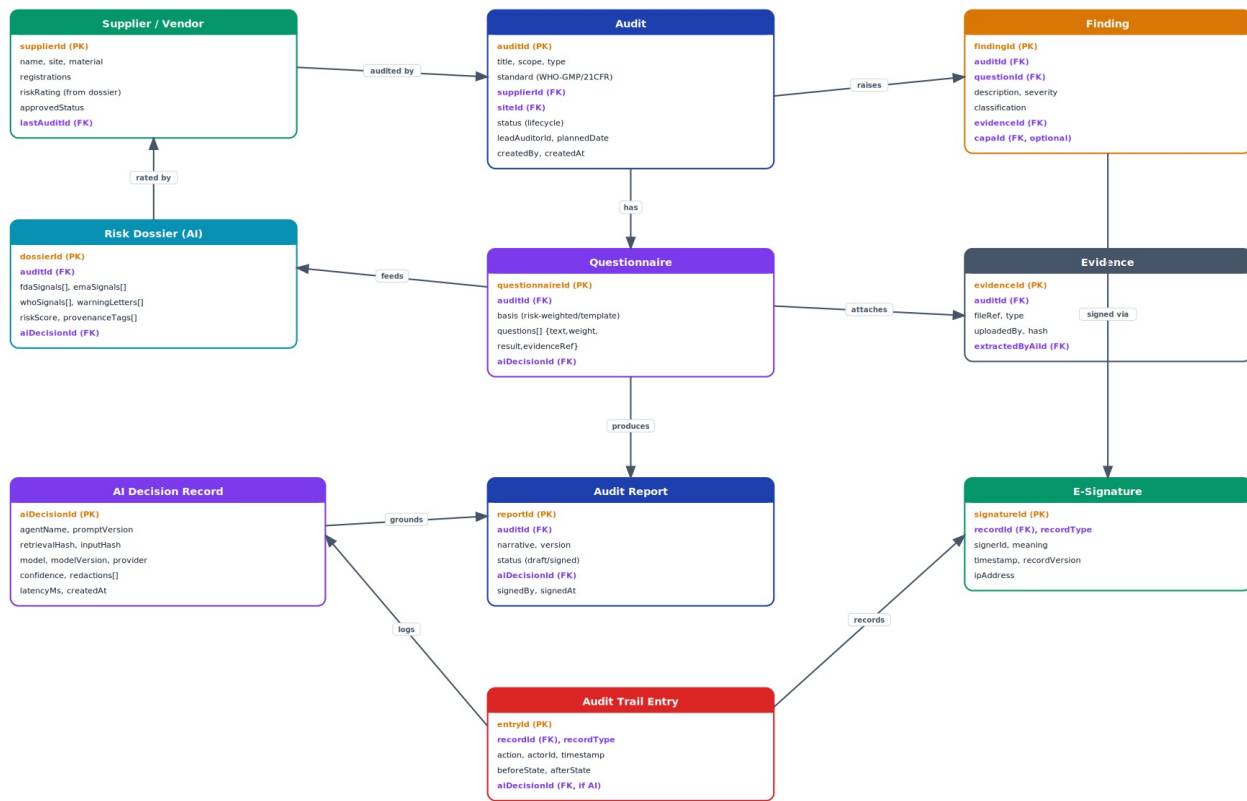
Capability	Description
Audit lifecycle engine	Configurable status flow with permission-gated transitions and e-signature sign-off.
Supplier risk dossier (AI)	Supplier Intel agent builds a provenance-tagged risk profile from public regulatory data.
Risk-weighted questionnaire (AI)	Audit Prep agent generates a supplier-specific questionnaire.
Evidence capture + Autofill (AI)	Attach evidence; Autofill agent extracts answers from uploaded documents.
Findings management	Raise, classify, link findings to CAPAs in the EQMS module.
Report generation (AI)	Report Assembler drafts a cited audit report for human review and e-sign.
Audit trail & reuse	Per-call AI audit trail; completed audits searchable, exportable, reusable.

6.2 — Data model: entities & relationships

The module's data model centres on the Audit entity, which links to a Supplier, a Risk Dossier, a Questionnaire, Findings, Evidence, and a Report. Two cross-cutting entities — the AI Decision Record and the Audit Trail Entry — attach to everything, which is what makes the module reproducible.

Audit Management — Entity / Data Model

Core entities and how they relate. Representative schema — verify field names against the live build.



KEY: # = primary key * = foreign key / link

Every entity links to AI Decision (if AI-touched) and to the Audit Trail — that is what makes the module reproducible.

Representative data model from known features + standard EQMS conventions. Confirm exact field names, PK/FK structure, and collections against `codex_backend_01` before external use.

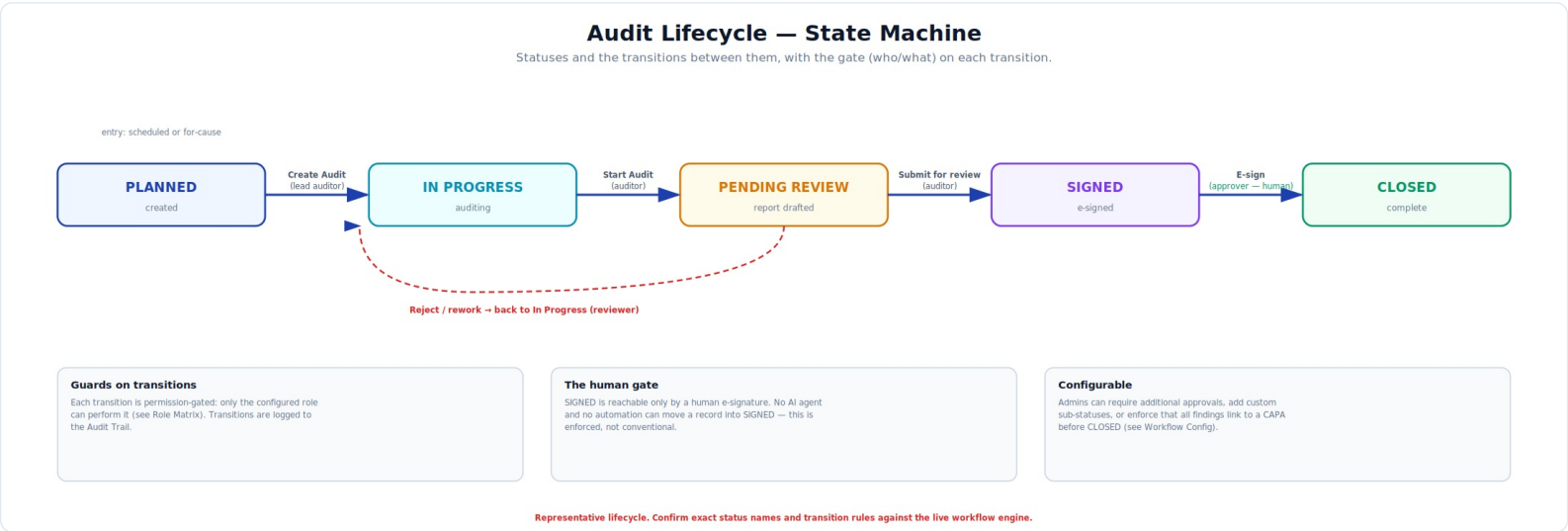
Reading the model

- **Audit** is the hub: every other entity links back to it via a foreign key.
- **Risk Dossier, Questionnaire, and Report** each carry an `aiDecisionId` linking to the AI Decision Record that produced them — any AI output traces to its exact generation.
- **AI Decision Record** stores the reproducibility payload: agent, prompt version, retrieval hash, model + version, confidence, redactions.
- **Audit Trail Entry** logs every action on every record (with before/after state), referencing the AI Decision Record when AI-driven.
- **E-Signature** binds signer, meaning, timestamp, record version — applied to Reports and (optionally) Findings.

Why the model matters for validation. In a CSV / 21 CFR Part 11 review, the question is always "can you prove who did what, when, and how?" This model answers it structurally: the Audit Trail captures who/what/when, and the AI Decision Record captures how (for AI steps).

6.3 — Lifecycle: the audit state machine

An audit moves through five statuses. Each transition is permission-gated (only a configured role can perform it) and logged. The single hard rule: only a human e-signature can move a record into SIGNED — no AI agent or automation can.



6.5 — Roles & permissions: the RBAC matrix

Access is role-based. Standard roles are shipped which admins can clone and customise. The matrix below shows representative default permissions.

Capability \ Role	Viewer	Auditor	Lead Auditor	Reviewer	QA Approver	Admin
View audits	✓	✓	✓	✓	✓	✓
Create audit	✗	✗	✓	✗	✗	✓
Run AI agents	✗	✓	✓	✓	✓	✓
Conduct / edit	✗	✓	✓	✗	✗	✓
Raise findings	✗	✓	✓	✓	✗	✓
Submit for review	✗	✓	✓	✗	✗	✓
Reject / rework	✗	✗	✗	✓	✓	✓
E-sign / approve	✗	✗	✗	✗	✓	✗*
Configure module	✗	✗	✗	✗	✗	✓

* Admins configure but should not self-approve quality records — separation of duties. Whether Admin can also hold an Approver role is itself a configurable (and auditable) policy decision.

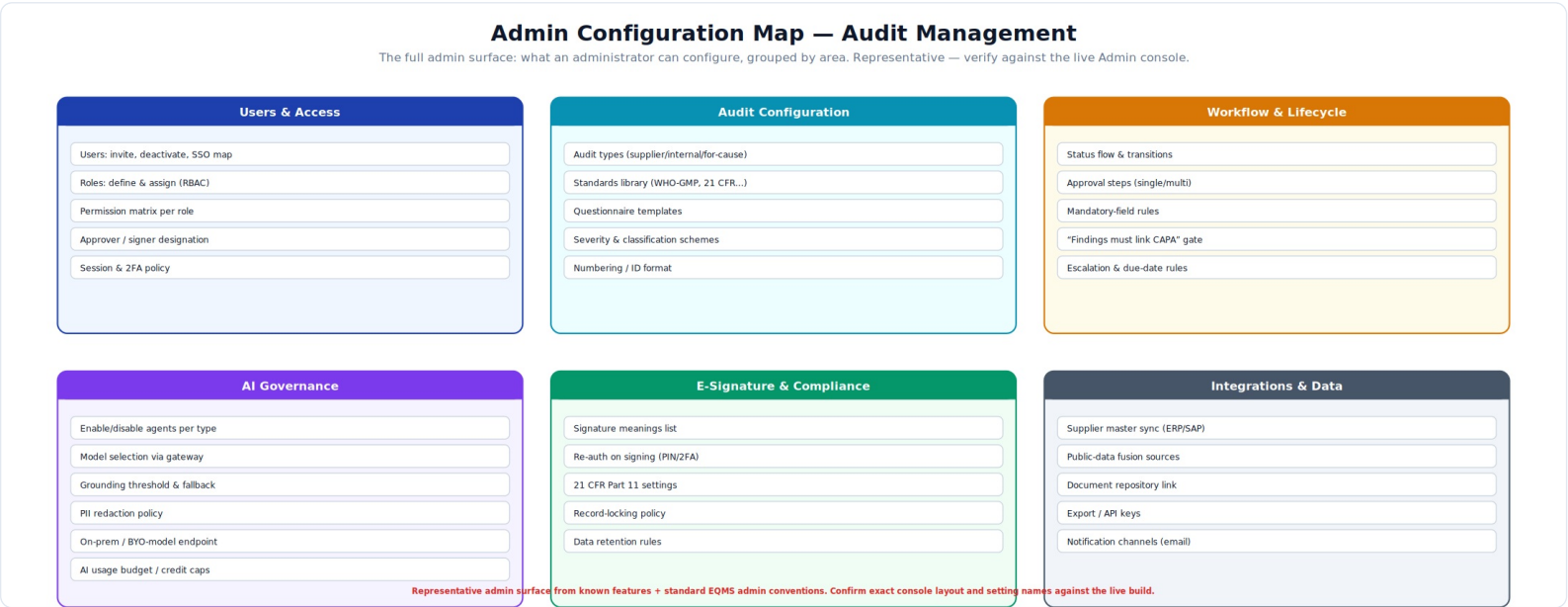
Separation of duties. The matrix encodes separation of duties: the person who conducts an audit is not necessarily the one who approves it, and the system administrator is kept distinct from the quality approver. Admins can tighten this further but should document any role that combines conduct + approval — inspectors scrutinise such overlaps.

Role configuration rules (exhaustive)

- **Standard roles are cloneable.** Start from a shipped role, clone it, adjust per-capability grants — never edit a standard role in place.
- **Capabilities are atomic.** Each row in the matrix is an independent grant; a custom role is any combination.
- **Scope can be constrained.** A role can be limited to certain audit types, sites, or suppliers.
- **Every grant change is itself audit-logged** — who changed which role's permissions, when.
- **Signer designation is separate** from the e-sign capability: a user must both hold the capability *and* be designated a valid signer for the record type.

6.6 — The full admin configuration surface

Everything an administrator can configure, grouped into six areas. The diagram is the whole surface; each area is detailed below.



6.7 — AI governance (controlling the AI)

Control	What it does	Admin guidance
Agent enablement	Enable/disable each agent per audit type	Conservative rollout: Supplier Intel + Audit Prep first; Report Assembler once trusted.
Model selection (gateway)	Route each agent to a chosen model	Cheaper model for extraction (Autofill); stronger for synthesis (Report).
Grounding threshold	Confidence floor for grounded output	Raise = conservative (safer, fewer outputs); lower = more forthcoming.
Fallback behaviour	What happens below threshold	Returns explicit "insufficient evidence" — never disable.
PII redaction	Strips identifiers before egress	Configure PII classes; enforce even on-prem for defence-in-depth.
Deployment / sovereignty	Cloud, hybrid, or on-prem endpoint	On-prem maturing — validate end-to-end before GMP reliance.
AI usage budget	Credit caps per tenant/type	Bound cost and prevent runaway automated usage.

The governance guarantee. Two properties cannot be configured away: every AI output is grounded-or-fallback (it never asserts what it cannot cite), and the AI never commits a record (a human always reviews and e-signs).

6.8 — E-Signature & compliance (21 CFR Part 11)

Setting	What it controls
Signature meanings	The list of meanings a signer selects (Approved, Reviewed, Authored).
Re-authentication on signing	Require credentials / PIN / MFA at the moment of signing.
Signature binding	Each signature binds signer identity + meaning + timestamp + record version.
Record locking	Whether/how a signed record is locked against further edits.
Data retention	How long records and audit trails are retained; legal-hold options.
Audit-trail immutability	The activity log is append-only; configure retention and export.

6.9 — Integrations & data

- **Supplier master sync (ERP/SAP)** — keep Suppliers in sync with the system of record.
- **Public-data fusion** — FDA (openFDA, inspections, Warning Letters), EMA EudraGMDP, WHO PQ — the live feeds behind Supplier Intel.
- **Document repository link** — connect controlled SOPs/standards from the Documents module.
- **Export / API** — controlled, versioned export and API access; managed API keys.
- **Notifications** — email (and other channel) notifications for tasks, approvals, escalations.

6.10 — Audit trail & reproducibility

The audit trail is structural, not a bolted-on feature. Every action on every record is logged; every AI step additionally writes an AI Decision Record. Together they let you reconstruct exactly how any audit, dossier, questionnaire, or report came to be. When an inspector asks "how did you reach this supplier risk rating?" or "how was this audit report generated?" the administrator or auditor opens the Audit Trail tab, expands the relevant AI step, and shows the exact inputs, sources, and model. That reproducibility is the module's core compliance value.

Audit Management in one line. The full audit lifecycle with AI that drafts the slow work and public data that informs risk — while a configurable workflow engine, role-based access, enforced human e-signature, and a per-call AI audit trail keep every output controlled, defensible, and reproducible. Admins tune behaviour; the compliance guarantees hold regardless.

Go-to-Market & Commercials

The free-2-PoC offer, the usage-based pricing model, the cost model summary, and the sales motion. Vendor-neutral.

The commercial offer

- **Free 2 PoCs to start.** Two proofs-of-concept on the customer's own data — typically Audit Management (PoC 1) and a Core EQMS module flow such as Deviation→CAPA (PoC 2) — at zero cost and zero commitment. Decision after ~3-4 weeks against pre-agreed written success criteria.
- **Sized to fit applicable subsidy.** For India SMB customers, the recurring subscription is structured to fit under the RPTUAS scheme thresholds, so a large share of subscription cost can be reimbursable.
- **No lock-in.** Exports of records and audit trails are available; customer leaves with everything that belongs to them.
- **On-prem & sovereignty as a premium add-on,** not the default; cloud-with-redaction is the standard PoC posture.

The pricing model — usage-aligned, transparent

Component	Structure
Per-site fee	Annual platform fee per manufacturing site / facility — covers infrastructure, validation posture, integrations.
Per-user fee	Annual fee per named full-edit user. Viewer / read-only seats free or low-cost.
AI usage credits	Monthly credit allowance with overage for additional usage. Credits weighted by action (a draft costs less than an audit report).
Add-ons	On-prem LLM deployment; premium support; partner-led implementation.

Anchored against the global stack at ~⅓ the price; under the 15% AI-of-price guardrail so AI is leverage, not the bill. Steady-state variable cost-per-customer trends to approximately \$1,900/yr; implied target price ~\$9,500/cust/yr at 80% margin (figures from the internal cost model, indicative).

The cost model summary

Bucket	What's in it
Variable per-customer	Cloud infra + AI inference (~\$1,600/yr, of which AI ~\$281)
Support & success	CSM time, partner enablement; scales with customer count
Demo & PoC	Free-PoC cost — pre-configured tenants, guided onboarding
Build & engineering	Fixed; amortized across the customer base

Cost/customer collapses with scale: ~\$43,900/customer at 10 customers → ~\$6,010 at 100 → ~\$2,312 at 1,000. The pricing isn't there to cover fixed cost early; it's there to be the right number for the buyer while staying above variable cost. Fixed cost is funded out of growth.

The sales motion

Motion	How it works
Bottom-up (QA champion)	A QA head experiences the free PoC, becomes the internal advocate, runs the buying process with leadership.
Top-down (executive)	Director / MD signs off on the PoC success criteria and the post-PoC subscription. Owner-led companies have short decision chains — favoured.
Partner-led	Pharma consultants and channel partners introduce Hawkeye to their client base; share success-based commercials.
Outbound	Targeted at the under-served segments the incumbents price out — SMBs, emerging-market manufacturers, export-aspiring firms.

The GTM principle. Sell the EQMS + supplier-audit value first to a single buyer; let that buyer's captive supplier base become the initial supply for the network later. SaaS-first, marketplace-second — never depend on two-sided liquidity for the early value proposition.

User Requirements Specification

The full URS: Part A foundational requirements (the regulated baseline) and Part B white-space requirements (the differentiators). Reads as the universal requirements set, not pharma-specific.

Document type	User Requirements Specification (URS)
System	AI-native EQMS + Supplier/Vendor-Audit Management Platform
Version	1.0 (DRAFT — for ratification by Quality, IT/CSV, Business owners)
Regulatory context	FDA 21 CFR Part 11 & Parts 210/211/820; EU GMP Annex 11; ISO 9001 / 13485 / 14971 / 42001; ICH Q9 / Q10; FDA QMSR (2026)

Conventions

Requirement ID format: URS-[AREA]-[nnn]. **Priority (MoSCoW):** M Must · S Should · C Could · W Won't-yet (future). Each requirement is testable and traceable. **Area codes:** GEN, SEC, ESG, ATR, DOC, DEV, CAP, CHG, TRN, CMP, RSK, MRV, SUP, CFG, INT, RPT, AIG, WS1-WS6.

Part A · A1 — Platform, security, records & signatures

General & platform (GEN)

ID	Requirement — the system shall...	Pri
URS-GEN-001	Be a multi-tenant, cloud-deliverable platform with logically isolated tenant data.	M
URS-GEN-002	Support cloud, hybrid, and on-premise deployment without change to user-facing function.	S
URS-GEN-003	Provide role-based dashboards and a task inbox per user.	M
URS-GEN-004	Operate in a validated state; support IQ/OQ/PQ and delineate vendor-vs-customer validation responsibility.	M
URS-GEN-005	Be available with a defined uptime target and support DR (RPO/RTO) appropriate to GxP.	S
URS-GEN-006	Maintain end-to-end traceability across modules (the digital thread).	M

Security & access control (SEC)

ID	Requirement	Pri
URS-SEC-001	Enforce role-based access control with configurable roles and per-capability permissions.	M
URS-SEC-002	Support individual named accounts only; prohibit shared logins for any action that can be signed.	M
URS-SEC-003	Support SSO and enforce multi-factor authentication; configurable session timeout and logout.	M
URS-SEC-004	Enforce separation of duties; make any role-overlap explicit and auditable.	M
URS-SEC-005	Constrain role scope by site, supplier, or module where required.	S

Electronic signature (ESG) & Audit trail (ATR)

ID	Requirement	Pri
URS-ESG-001	Apply 21 CFR Part 11 / Annex 11-compliant e-signatures binding signer + meaning + timestamp + record version.	M
URS-ESG-002	Require re-authentication at the moment of signing.	M
URS-ESG-003	Maintain a configurable list of signature meanings.	M
URS-ESG-004	Lock a signed record against edit; require a new controlled version for any change.	M
URS-ATR-001	Maintain a secure, time-stamped, append-only audit trail of all CRUD/transition/sign actions (actor, before/after, reason).	M
URS-ATR-002	Make the audit trail human-readable, searchable, exportable, and prevent its modification.	M
URS-ATR-003	Ensure records meet ALCOA+ and enforce a configurable retention and legal-hold policy.	M
URS-ATR-004	Provide tamper-evident record integrity (per-record cryptographic hashing of signed snapshots).	S

URS · A2 — EQMS modules · A3 — Supplier audit · A4 — AI

A2 · Document Control (DOC), Deviation (DEV), CAPA (CAP), Change (CHG)

ID	Requirement — the system shall...	Pri
URS-DOC-001	Manage controlled-document lifecycle: author → review → approve → effective → periodic review → retire, with enforced version control.	M
URS-DOC-002	Retain full version history with change summary between versions.	M
URS-DOC-003	Trigger downstream actions on document change (e.g. assign retraining).	S
URS-DEV-001	Capture a deviation/NC with structured intake, risk classification, affected product/process/batch.	M
URS-DEV-002	Support structured investigation (incl. 5-Why) and documented disposition with impact assessment.	M
URS-DEV-003	Link a deviation to one or more CAPAs and propagate the linkage end-to-end.	M
URS-CAP-001	Manage closed-loop CAPA lifecycle: initiate → investigate → action plan → implement → verify effectiveness → close.	M
URS-CAP-002	Prevent closure until effectiveness verification is recorded; support reopen/supersede.	M
URS-CAP-003	Enforce risk-based due dates and escalate overdue actions.	S
URS-CHG-001	Manage change requests with impact/risk assessment, multi-step approval, controlled implementation.	M
URS-CHG-002	Link a change to affected documents, validation, training, supplier re-qualification.	M
URS-TRN-001	Assign, track, and record training and competency against roles/SOPs; auto-assign on document revision.	M
URS-CMP-001	Manage complaints/events: intake → triage → investigation → regulatory-reporting assessment → CAPA linkage.	M
URS-RSK-001	Provide quality risk management usable standalone and embedded in other modules (ICH Q9).	M
URS-MRV-001	Aggregate cross-module quality KPIs into a management-review view (ICH Q10).	S

A3 · Supplier / vendor audit (SUP)

ID	Requirement	Pri
URS-SUP-001	Maintain a supplier master with qualification status, ASL membership, certifications, criticality.	M
URS-SUP-002	Support initial supplier evaluation and risk classification to set audit depth and cadence.	M
URS-SUP-003	Capture quality agreements and link to the supplier record.	S
URS-SUP-004	Continuously monitor supplier performance and re-score risk on a defined cadence.	S
URS-SUP-010	Manage the audit lifecycle (plan → prepare → conduct → findings → report → sign-off → close) with configurable phases.	M
URS-SUP-011	Support pre-audit prep: scope, auditor qualification, agenda, pre-audit questionnaire, pre-reads.	M
URS-SUP-012	Support on-site/remote execution: questionnaire-driven evidence capture, finding classification by criticality.	M
URS-SUP-013	Support post-audit follow-up: cited report, supplier CAPA request, evaluation, approval decision — all e-signed and trailed.	M
URS-SUP-014	Maintain searchable, reusable repository of completed audits, exportable as controlled versioned reports.	S
URS-SUP-015	Trigger for-cause audit automatically from defined events.	S

A4 · AI governance baseline (AIG) + Config/Integration/Reporting

ID	Requirement	Pri
URS-AIG-001	Treat AI as decision-support only: AI may draft but never commits, approves, or signs a record.	M
URS-AIG-002	Allow each AI capability to be enabled/disabled per tenant and per module.	M
URS-AIG-003	Function as a deterministic workflow/records system with all AI disabled.	S
URS-AIG-004	Redact PII/sensitive data before sending to any external model.	M
URS-AIG-005	Govern AI access by the same RBAC as the rest of the system.	M
URS-AIG-006	Support an AI-governance framework consistent with ISO 42001 for GxP-impacting steps.	S
URS-CFG-001	Allow admins to enable/disable modules, configure workflows/states/transitions, mandatory fields without code change.	M
URS-CFG-002	Maintain a configurable standards/controls library as data, and per-tenant vocabulary overrides.	S
URS-INT-001	Integrate with ERP/LIMS/MES and a document repository via documented APIs.	M
URS-RPT-001	Provide configurable dashboards, trend analysis, and exportable reports across modules and sites.	M

URS · Part B — The differentiating requirements

Part B translates the six documented white spaces (Part 4) into testable requirements. Each white space is introduced, then specified.

WS1 — Couple internal quality to a live supplier-audit network.

ID	Requirement	Pri
URS-WS1-001	Treat a supplier-audit finding as a first-class input to internal quality: a finding shall create a linked CAPA/change traceable both ways.	M
URS-WS1-002	Allow a completed audit to be shared with, or reused by, multiple authorised buying organisations under controlled permissions.	C
URS-WS1-003	Maintain a supplier identity consistent across audits and buyers (entity resolution).	S
URS-WS1-004	Enable a buying organisation's qualified suppliers to become discoverable participants in an audit network.	W
URS-WS1-005	Govern multi-party data sharing with explicit, auditable consent and selective disclosure.	S

WS2 — Reproducible, defensible AI in validated environments.

ID	Requirement	Pri
URS-WS2-001	Record, for every AI-assisted output, a reproducibility record: inputs/sources retrieved, prompt/version, model + version, confidence indicator.	M
URS-WS2-002	Ground every AI output in retrievable source data and cite each material claim; return "insufficient evidence" rather than an unsupported answer.	M
URS-WS2-003	Make the AI reproducibility record part of the audit trail and presentable to an inspector.	M
URS-WS2-004	Allow admins to set a grounding/confidence threshold and to choose/route the underlying model (incl. on-premise) per capability.	S
URS-WS2-005	Meter and log AI usage per action for cost transparency and governance.	C

WS3 — Live external/public-data fusion into decisions.

ID	Requirement	Pri
URS-WS3-001	Ingest public regulatory data (FDA inspections/warning letters/recalls, EMA, WHO) and associate it with relevant supplier/site.	S
URS-WS3-002	Fuse external data into a continuously updated supplier-risk profile across multiple dimensions, with provenance tagging.	S
URS-WS3-003	Raise early-warning alerts when new external signals materially change supplier risk.	C
URS-WS3-004	Use external-data-derived risk to inform audit cadence and questionnaire focus (risk-weighted prep).	C

WS4 — True interoperability & cross-system digital thread.

ID	Requirement	Pri
URS-WS4-001	Expose open, documented, versioned APIs for all major objects supporting read and write.	M
URS-WS4-002	Support event-driven integration (webhooks/messaging) so external systems can react in near-real-time.	S
URS-WS4-003	Maintain provenance and a common data model across integrated sources (the cross-system digital thread).	S
URS-WS4-004	Provide pre-built connectors for common ERP/LIMS/MES and a documented custom-connector pattern.	C
URS-WS4-005	Handle unstructured inbound data (scanned reports, certificates, emails) via document intelligence/OCR with provenance to source.	S

WS5 — Affordable, validated, intelligent quality for SMBs/emerging markets.

ID	Requirement	Pri
URS-WS5-001	Near-zero-touch onboarding via pre-configured standard-aligned templates.	S
URS-WS5-002	Low/no-cost evaluation path (scoped PoCs on the customer's own data) before commitment.	C
URS-WS5-003	Transparent, usage-aligned commercial terms suitable for small teams; viewer/read-only access low or no cost.	C
URS-WS5-004	Usable by a lean quality team — minimal training for core tasks — without sacrificing compliance controls.	S

WS6 — A genuinely industry-agnostic compliance engine.

ID	Requirement	Pri
URS-WS6-001	Separate the fixed processing engine from industry-specific configuration (standards, vocabulary, rules, workflows, templates), all held as data.	S
URS-WS6-002	Allow a new industry/regulatory regime to be added as a configuration pack without changing the core pipeline.	C
URS-WS6-003	Validate data against any configured standard's controls generically.	S
URS-WS6-004	Produce the appropriate validation/compliance/certification output for the configured industry from a common reporting engine.	C

URS status. v1.0 DRAFT. Priorities indicative and must be ratified by Quality, IT/CSV, Procurement, and Business owners before driving design and validation. Part B is forward-looking — several items are differentiators / future bets, not assertions that they are all built today. Regulatory references current to early 2026; confirm against primary sources. In a regulated programme this URS is itself a controlled document.

Honesty Register & Roadmap

Everything to not overclaim, in one place. The one page to read before any external commitment.

What this part is. Across the development of this platform there are claims that are *verified-strong*, claims that are *partial/maturing*, and claims that are *aspirational*. They are kept honest throughout this document, but they are here consolidated in a single register so any external presentation, sales conversation, investor pitch, or regulatory discussion can be calibrated against this list. If a statement is not on the VERIFIED side, it should not be presented as built.

9.1 — What is VERIFIED (code-traced this session)

Claim	What the code shows
Five-pillar architecture is real and discrete	All five pillars map to actual files/directories: crawlers/parsers/pdf_extract (P1), normalize/+entity_resolution (P2), compliance/+risk (P3), reportDataService+auditReportAgent (P4), auditTrailService+buildSnapshotHash (P5).
Industry-agnostic engine, by construction	vocabularyService, universalModuleConfigService (industryProfile field, 15 modules toggleable), defaultStandards as data, standardRegistryService, WorkflowDefinitionService — all confirm engine/config separation.
Pluggable AI is real	Gateway (Anthropic/OpenAI/Gemini/local), grounded generation, PII redaction, governance (catalog/cost/permissions/usage); per-module drafters; 6 audit agents.
Every module shares one architecture	Same model+workflow+audit-trail+config backbone across audit, capa, deviation, docControl, change; crossModuleService wires them.
Tamper-evident immutable record	SHA-256 snapshot hashing + append-only Part-11/Annex-11 trail + AI decision record — code-confirmed.

9.2 — What is PARTIAL / MATURING (built but not yet proven end-to-end)

Item	Honest status
On-prem LLM deployment	Real scaffold in wave3/onPremLlmDeploy.js with frozen IQ/OQ/PQ validation requirements. Available, validation-gated, NOT proven in production. Do not promise turnkey.
Wave 3 predictive AI	driftMonitor, predictiveCapaEffectiveness, iotEquipmentFusion — scaffolds exist; earliest maturity tier.
Cross-company / shared-audit network	wave2 crossCompanyAudit primitives + marketplaceCatalog; no live multi-party liquidity yet. Audit-network is a roadmap bet, not a shipped network.
Non-pharma industry packs	Engine supports it; only pharma instantiated. Other verticals are configuration work.
Management Review, Training, some other modules	Built at module-config level; depth varies; some need productisation.

9.3 — Common overclaims to AVOID

Don't say	Say instead
"Blockchain" / "chained ledger"	"Tamper-evident immutable record" — per-record SHA-256 hash + append-only audit trail. No chained ledger in code.
"MCP-compliant tool runtime"	"Custom tool-calling runtime." wave2/toolCallingRuntime.js has no MCP protocol/handshake; the gateway "MCP path" comment is a label, not an implementation.
"On-prem AI proven in production"	"On-prem available, validation-gated." Real scaffold; needs end-to-end validation per ONPREM_VALIDATION_REQUIREMENTS .
"Industry-agnostic in production today"	"Industry-agnostic by design; pharma proven; other verticals are configuration packs on the roadmap."
"AI-native is our differentiator"	"AI presence is now table stakes." Edge is the combination : EQMS + supplier-audit coupling + reproducible AI + public-data fusion + affordability. Not AI presence alone.
"Live shared-audit marketplace"	"Roadmap. Primitives exist; two-sided liquidity to be built."

The roadmap: where the PARTIAL/THIN items are heading

Item	Current	Direction / what would close it
On-prem LLM	Scaffold + validation requirements frozen	End-to-end IQ/OQ/PQ against a reference customer; documented reference deployment; partner-led validation packages.
Wave 3 predictive AI (CAPA effectiveness, drift, IoT fusion)	Service scaffolds present	Sufficient historical data to train and validate predictions; reference customer use cases to prove ROI before broad rollout.
Cross-company / shared-audit network	Primitives + marketplaceCatalog only	SaaS-first GTM creates captive supplier base; permissioned audit-sharing among customers' suppliers; gradually open to third-party participants. The classic marketplace cold-start, attacked via SaaS supply.
Tool runtime (custom → MCP)	Custom, not MCP-compliant	If buyer demand or ecosystem requires, evolve to MCP. Currently a labelling rather than capability issue.
Non-pharma packs	Pharma only instantiated	Sequence: Food & Beverage (HACCP) → cosmetics / blood / tissue → automotive / aerospace supplier-audit angle. Each = a config pack, not a rebuild.
Management Review module	aggregateQualityKPIs + wave2 mrm	Productise the dashboard + governance loop; standardise the periodic review cycle and KPI templates.
RFQ Procurement	THIN	Either deepen (if customer pull) or deprecate from default-on. Currently a placeholder.

9.4 — Standing verification reminders

- **The code-verified state in this document reflects the depth-1 main-branch clone at the date of build.** Re-verify against the deployed branch before any external use.
- **UI labels and admin-console wording remain representative** in user-facing guides until reconciled against the live application's exact strings.
- **Competitor capabilities are generalized from public 2025-26 positioning** and may vary by version/configuration. Confirm specifics before any competitive talk.
- **Market figures (TAMs, CAGRs) are from third-party research firms**, ranges shown, not summed. Do not pitch headline TAMs without the addressable wedge qualifier.
- **The 2026 regulatory dates (FDA QMSR, ISO 9001:2026, IA9100, IATF 16949:2027, ISO 42001)** are sourced to industry reporting; confirm against the standards bodies before external citation.
- **Vendor-reported figures** (e.g. Qualifyze's audit-database size, "∼65% time saving") are attributed to their sources and not independently verified.

The single principle behind this register. Hawkeye is genuinely strong where it is strong, and genuinely partial where it is partial. Both are good to say. What is fatal is to say partial things as if they were proven — because regulated buyers, partners, and investors all do the diligence. The discipline is to overclaim nothing and let the verified-strong items carry the story, while the partial items show the roadmap. That discipline is what makes the rest of this document trustworthy.

Version 1.0 · April 2026 · ∼65 pages · PDF master reference

End of master reference. What follows in practice are the companion artifacts: the standalone Audit Management spec (referenced in Part 6), the full URS (referenced in Part 8), the Verified Architecture document, the Industry Research Paper, the Per-Sector Market Analysis, and the GTM/pricing/cost-model details. Each can be presented standalone. This master document is the canon they collectively support.